

Lesson 10

Reporting Standards and Procedures

Disclaimer

What you will go through in this course, is highly highly niched skills that can make you a highly valuable asset in an organization, or an overnight criminal when things are done without permission, or the right ethical considerations.

You CAN land in trouble if you breach the computer misuse act, and in no capacity I will be vouching for you, sanctioning you, or even allowing you to attack on properties that are not own by me, or for lesson purpose.

So please, help me to help you by not doing anything taught in class, onto someone else.

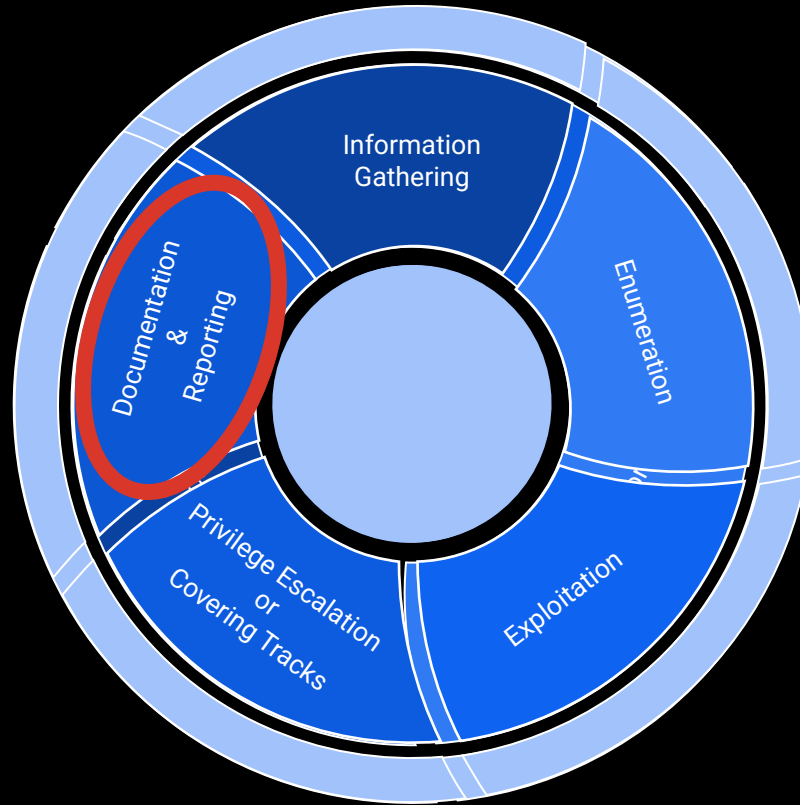
Lesson sequence

Lecture

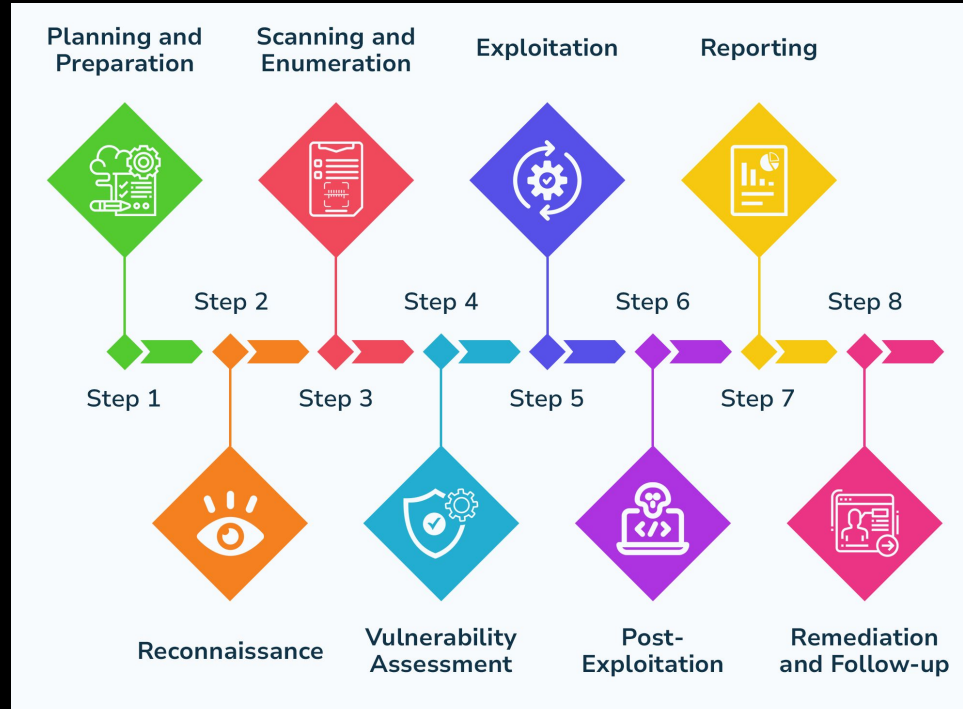
Recap

Start of Group Project Hacking

Penetration Testing Life Cycle



The steps to securing an organization/asset in VAPT



Your best friend is to collect screenshots

At every juncture of the engagement, always take screenshots to ensure you have all evidence.

Recommended note taking apps:

Notion

Obsidian

MS OneNote

So why is Reporting important?

Reporting provides a unified standard documentation for all stakeholders to understand your findings, assess priority and severity.

Your reports can be in multiple “language” or a single templated language.

Your report represents your work.

Key elements to have in a report

Executive summary

Introduction

Scope of work

Attack narrative/Findings

Diagrams

Recommendations

Conclusion

Executive summary

If I only have 5 minute to decide if your report is worthy to read, I will read your Executive summary and conclusion to conclude if the time is worth it.

Usually a one or two paragraph content that encompasses your report.

5 W 1 H, key details, findings, recommendations.

Always indicate business impact here to capture attention

Example

ABC Company was contracted to conduct a VAPT on XYZ Web application. During the 10 days engagement, a total of 10 criticals, 5 highs, 4 medium and 3 lows were found. Of the 22 findings, 4 were identified to impact business operations if exploited. One such finding include a remote code execution in the web server, allowing an attacker to have full control over the XYZ Web application network. We have recommended immediate patching through code sanitization, and proposed a defence in depth approach to further strengthen the security posture of the application.

Introduction

You take your time to introduce the project here. Introduce your team members if needed, and what experiences you have, or as a team.

You will then introduce your client in the report, and also introduce methods employed and how scoring is done.

Usually you put your methodologies here. (ASVS/ISVS/MAS-TRM)

CVSS

Once common measure to use when measuring severity of a vulnerability is to use the Common Vulnerability Scoring System (CVSS)

<https://www.first.org/cvss/>

In our class, we use CVSS 3.1

<https://www.first.org/cvss/calculator/3-1>

And we will only use the BASE SCORE for everything related to this module.

Example of CVSS

If you have attempt an unauthenticated SQL injection which allows you to read the database but NOT change the form of data nor affect the availability, then your CVSS would look something like this

Base Score		7.5 (High)
Attack Vector (AV)	Scope (S)	
☒ Network (N) ☐ Adjacent (A) ☐ Local (L) ☐ Physical (P)	☒ Unchanged (U) ☐ Changed (C)	
Attack Complexity (AC)	Confidentiality (C)	
☒ Low (L) ☐ High (H)	☐ None (N) ☐ Low (L) ☒ High (H)	
Privileges Required (PR)	Integrity (I)	
☒ None (N) ☐ Low (L) ☐ High (H)	☒ None (N) ☐ Low (L) ☐ High (H)	
User Interaction (UI)	Availability (A)	
☒ None (N) ☐ Required (R)	☒ None (N) ☐ Low (L) ☐ High (H)	

Example of CVSS

If you have attempt an unauthenticated RCE which allows you to have system access, which also means you have jumped from an application to a system access, then it would look like this

Base Score

10.0
(Critical)

Attack Vector (AV)

Network (N) Adjacent (A) Local (L) Physical (P)

Attack Complexity (AC)

Low (L) High (H)

Privileges Required (PR)

None (N) Low (L) High (H)

User Interaction (UI)

None (N) Required (R)

Scope (S)

Unchanged (U) Changed (C)

Confidentiality (C)

None (N) Low (L) High (H)

Integrity (I)

None (N) Low (L) High (H)

Availability (A)

None (N) Low (L) High (H)

CVSS

Attack Vector: How the attack can be delivered

Attack Complexity: Must the attacker have a lot of pre-conditions?

Privileges Required: Must the attacker be an authenticated user?

User Interaction: Must the attacker coerce another victim into doing an action

Scope (s): Has the attacker changed the impact from one attack surface to a larger attack surface (from application to system?)

Confidentiality: To what extent does an attack have control/impact over data confidentiality (See secrets?)

Integrity: To what extent does an attack have control/impact over data Integrity (Change data?)

Availability: To what extent does an attack have control/impact over data availability (Shutdown service?)

Scope of work

The scope of work is usually defined as a list of scopes pre-approved by the client. This also means IP addresses, domains and even potential libraries. At times, you may also include your dedicated IP you are using to conduct the VAPT.

You may attempt to articulate the priority levels here (P0 to P3)

P0 - Must solve in 24 - 48 hours

P1 - Must solve in 72 hours

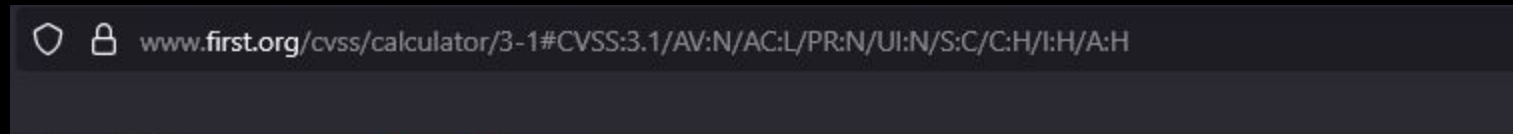
P2 - Must solve in 1 week - 1 month

P3 - Up to 90 days

Anything after is called “extension required”

Attack narrative/Findings

This is where you get to list down each finding, attach a CVSS score, and give it a name. The CVSS Metrics is taken from the URL where you created the CVSS score.



Name	Finding A	CVSS	10.0
Summary			
CVSS Metrics	3-1#CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H		
Steps to reproduce	1) Login 2) .. 3) ..		

Diagrams

At this portion, you add diagrams which allows you to show your audience how your infrastructure was deployed for the attack testing, and how you were interacting with the target sites.

This also include any infrastructure used and the diagrams between you and the app while testing.

Recommendations

You list a table of recommendation, from most severe to least severe. You should also discuss with the client on prioritization of issues found.

Severity: Low, Medium, High, Critical (follow CVSS)

Priority: P0, P1, P2, P3 (P0 being most important, P3 being least and can delay)

Sometimes, a Critical issue can be a P1 or P2.

Issue	Severity	Recommendation	Priority
Issue 1 (Finding 1)	10.0 (Critical)	Patch the vuln	P0

Conclusion

Now you have done the hard work in ensuring your work is well documented, write a conclusion that puts together every essence of your work.

You can also include limitations, what could have been done if more time given, and give credit to the client for being vigilant and willing to work for a change.

A VAPT can ruin someone's job. So you have to balance both attacking and praising in the same report to achieve a balance in optics and objective achieved.

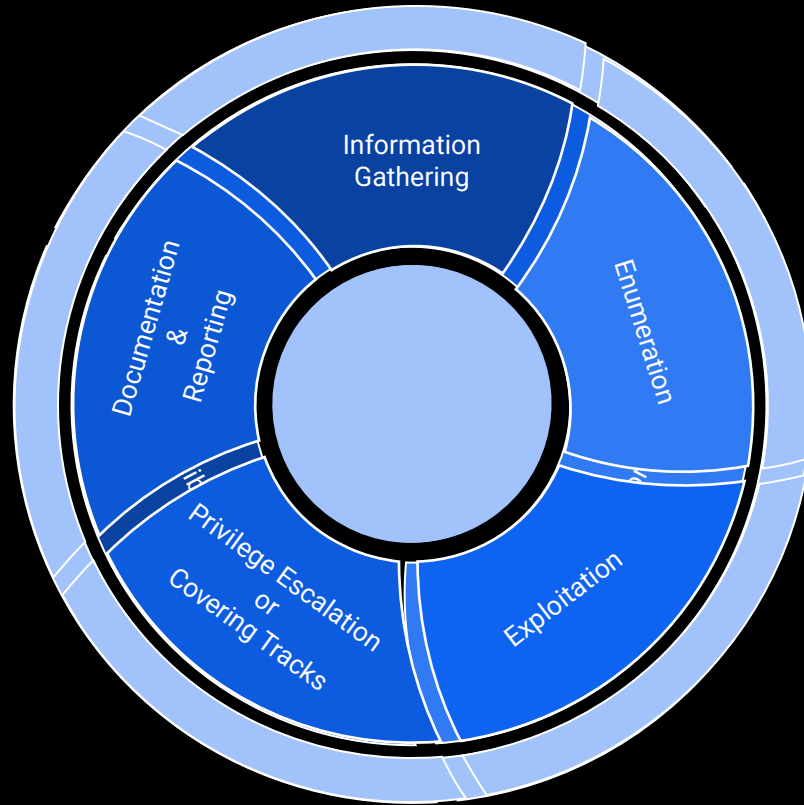
So you have a report, what is next?

Present your work

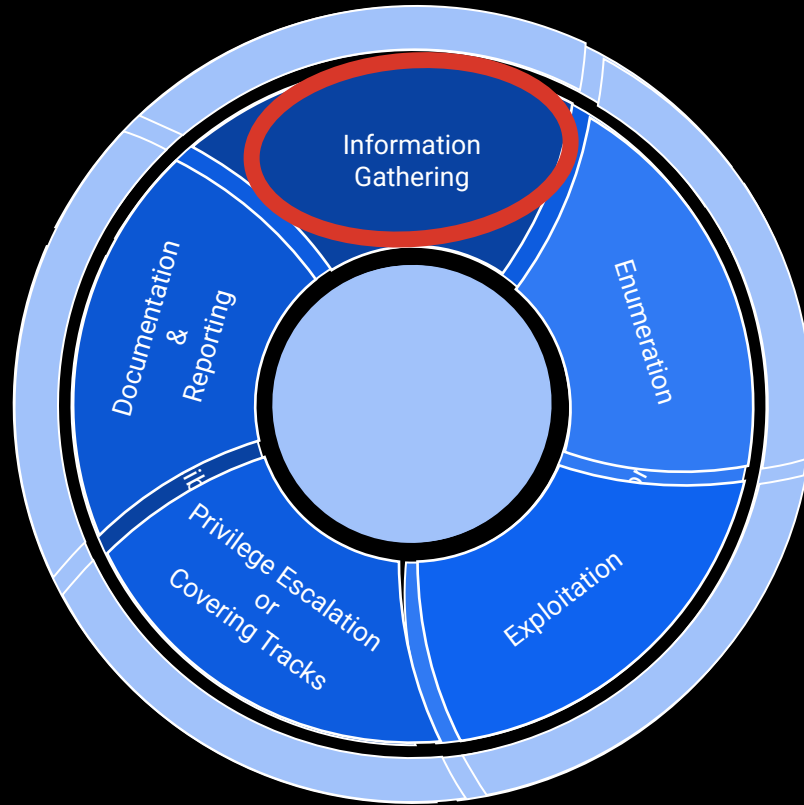
So using your report, generate a presentation slides

Your presentation slide should cover key pointers that you must cover within the time given. A reader have ample time to read your detailed report, but only 10-15mins in your presentation. Hence, focus on the important points.

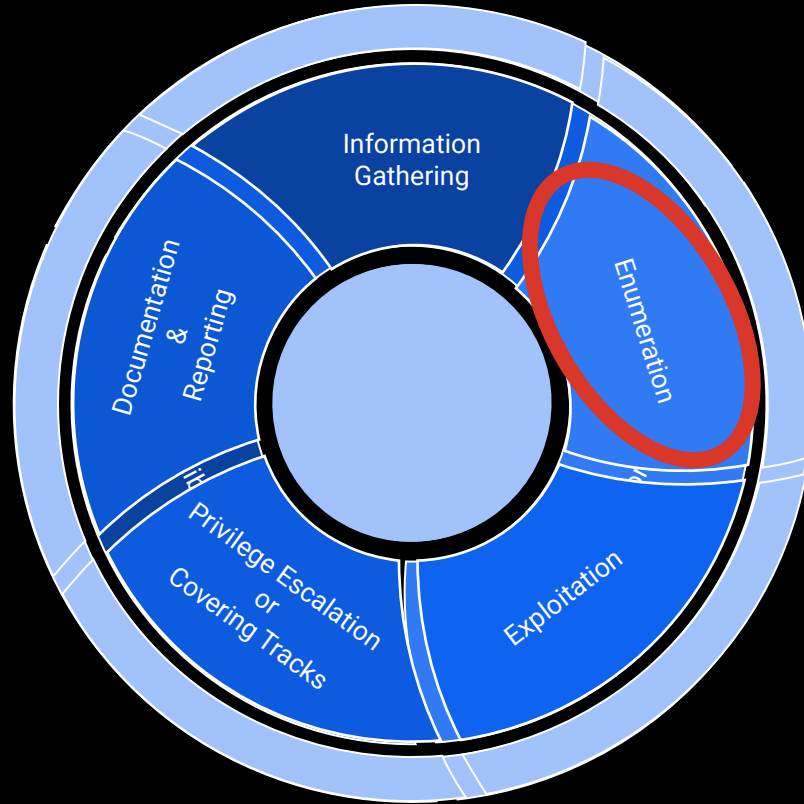
Recap



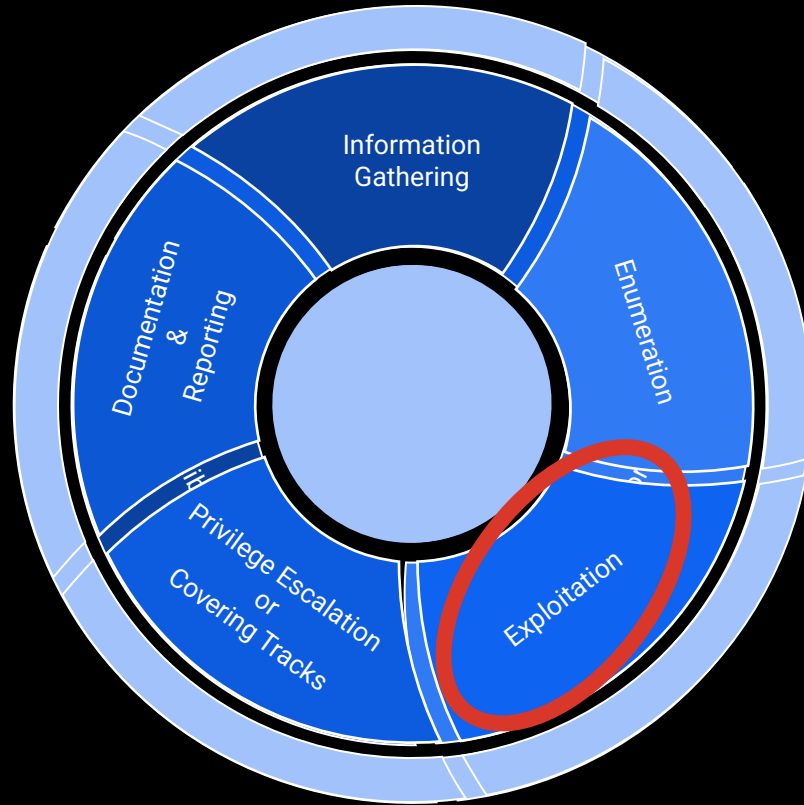
Recap



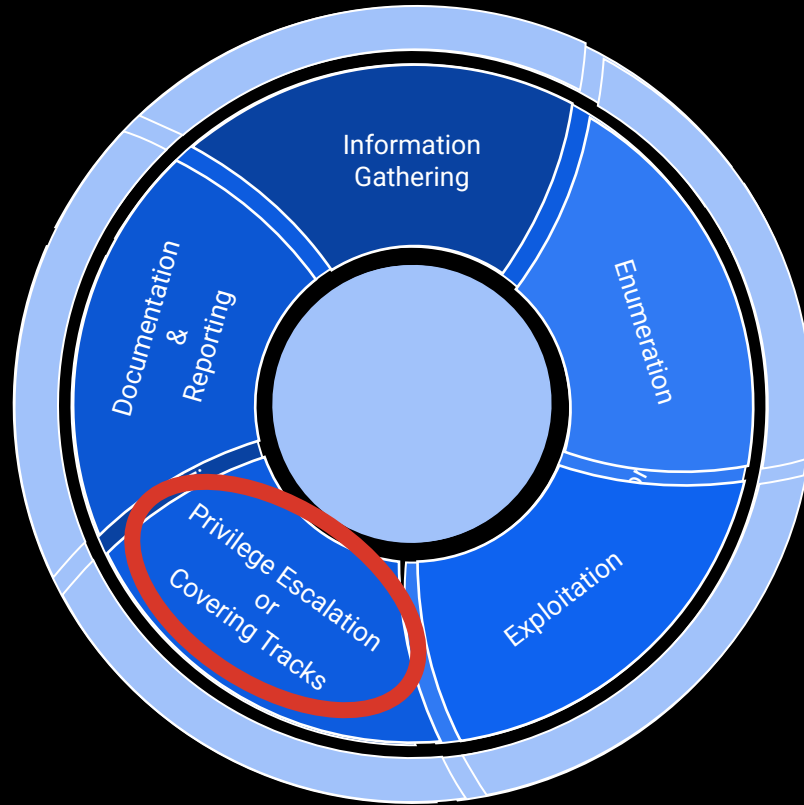
Recap



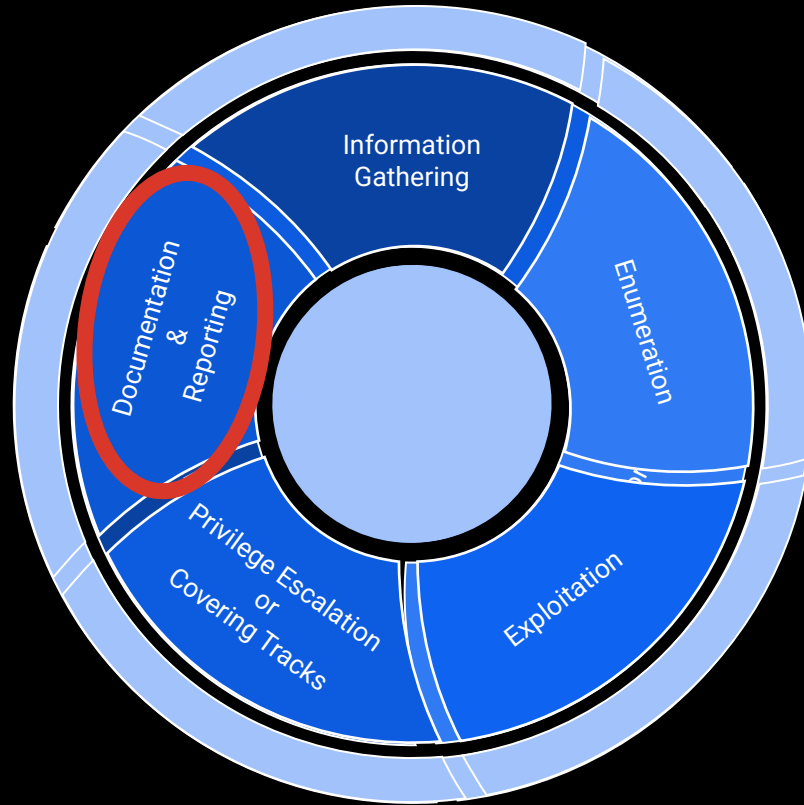
Recap



Recap



Recap



TL;DR

1. Offensive Security is not 100% technical work. 60% technical work, 40% report writing
2. Your craft is 20% learning, 80% practice
3. You will always face new challenges, but your fundamental learning methodology stays the same
4. It will never be about certificates or achievements, but how you carry out your mental resilience, your steps to thinking out of the box, and showing you have what it takes to become an offensive security professional
5. Practice Practice Practice. :)

Break Time

So have you finished your Portswigger academy?

Minimally 3 completed for each topic from the following topics:

SQL Injection

Authentication

Path Traversal

Command Injection

SSRF

XXE Injection

NoSQL Injection

Server-side topics

For complete beginners, we recommend starting with our server-side topics. These vulnerabilities are typically easier to learn because you only need to understand what's happening on the server. Our materials and labs will help you develop some of the core knowledge and skills that you will rely on time after time.

SQL injection

SQL injection is an old-but-gold vulnerability responsible for many high-profile data breaches. Although relatively simple to learn, it can potentially be used for some high-severity exploits. This makes it an ideal first topic for beginners, and essential knowledge even for more experienced users.

[Go to topic →](#)

18 Labs

Authentication

[Go to topic →](#)

14 Labs

Path traversal

[Go to topic →](#)

6 Labs

Command injection

[Go to topic →](#)

5 Labs

Business logic vulnerabilities

[Go to topic →](#)

11 Labs

Information disclosure

[Go to topic →](#)

5 Labs

Access control

[Go to topic →](#)

13 Labs

File upload vulnerabilities

[Go to topic →](#)

7 Labs

Race conditions

[Go to topic →](#)

6 Labs

Server-side request forgery (SSRF)

[Go to topic →](#)

7 Labs

XXE injection

[Go to topic →](#)

9 Labs

NoSQL injection

[Go to topic →](#)

4 Labs

API testing

[Go to topic →](#)

5 Labs

Web cache deception

[Go to topic →](#)

5 Labs

Start of Group Project Hacking

Please refer to announcements (Will be released after breaktime)